

OWASP ZAP

DAST y análisis de seguridad Web en ambientes autorizados.

Qué es OWASP ZAP

OWASP ZAP (Zed Attack Proxy) es una herramienta open source para pruebas de seguridad de aplicaciones web dentro del ecosistema OWASP. Puede funcionar como proxy de interceptación y realizar análisis pasivo y activo, ayudando a QA a incorporar verificaciones orientadas a DAST en ambientes autorizados.

Passive Scan

Passive Scan analiza el tráfico que pasa por ZAP sin atacar activamente el objetivo. Puede señalar headers, atributos de cookies, mixed content y otras señales observables de seguridad. Es un buen punto de inicio porque tiene menor riesgo de modificar el estado de la aplicación.

Active Scan

Active Scan envía requests diseñados para investigar posibles vulnerabilidades. Es intrusivo y puede modificar datos o afectar disponibilidad; úselo solo contra objetivos explícitamente autorizados y ambientes controlados, con alcance, credenciales y condiciones de parada acordadas.

Quick Start y proxy

Use Quick Start para una exploración guiada o configure navegador/aplicación para enviar tráfico por ZAP. Confirme alcance, manejo de certificados HTTPS y autenticación antes de escanear. Comience navegando y revisando hallazgos pasivos antes de acciones más invasivas.

QA y DAST en CI

ZAP puede apoyar checks DAST automatizados en CI/CD, pero el pipeline debe definir objetivo, autenticación, política baseline, riesgo aceptado y criterios de fallo. Trate los hallazgos como entradas para triage y no como vulnerabilidades confirmadas automáticamente; correlacione evidencia y revisión de seguridad.

Punto de atención

Las pruebas de seguridad requieren autorización. Nunca ejecute scans activos contra producción, terceros o ambientes fuera del alcance acordado. Proteja credenciales y tráfico capturado, evite datos sensibles en reportes e involucre especialistas de seguridad en hallazgos de alto impacto.